

Home SOC Lab: Hydra SMB Brute-Force Investigation Report

Analyst: Sree Saran S S **Date:** August 4, 2026 **SIEM:** Splunk Enterprise 10.4.2 **Incident:** Credential brute force + successful compromise

Objective: Simulate an SMB credential brute-force attack from Kali against a Windows 10 endpoint and detect it in Splunk using Windows Security Event Log telemetry.

Background: What is SMB and Why Attack It?

SMB (Server Message Block) is the network protocol Windows uses to share files, printers, and other resources between computers. Modern versions - SMB2 and SMB3 - run over TCP port 445; the legacy SMB1 also uses port 139. Because SMB requires authentication before granting access to shared resources, it is a natural target for credential attacks: any exposed SMB port is essentially advertising an authentication endpoint. Historically, SMB was the transport for the EternalBlue exploit and the WannaCry ransomware outbreak in 2017. In this exercise, SMB2 on the Windows victim was targeted with a small dictionary-based brute-force attack to test whether Splunk would detect the resulting flood of failed logons.

1. Lab Architecture

Same three-VM SOC lab used for the prior Nmap investigation. All VMs communicate over a Bridged Adapter on the local network (192.168.29.x).

VM	Role	IP	Purpose
Splunk Enterprise 10.4.2 (Ubuntu 22.04)	SIEM / Indexer	192.168.29.97 (static)	Ingest, index, and search Windows security telemetry
Windows 10 Pro (DESKTOP-9M1T24R)	Victim endpoint	192.168.29.226	Target machine; SMB (445) exposed; testvictim account brute-forced
Kali Linux 2026.2	Attacker	192.168.29.163	Runs Hydra with a small credential wordlist against Windows SMB

2. Preparation Steps

Target Account Created on Windows

A dummy local user was created on the Windows VM to act as the brute-force target, so the analyst's own day-to-day account was not exposed to lockout risk during testing:

```
net user testvictim Password123 /add
```

Wordlists Created on Kali

Two small wordlists were built on Kali. The password list included Password123 at position 9 so Hydra would find a match; the username list included testvictim. Small lists were used deliberately to keep the attack duration short and the log volume readable.

```
Session Actions Edit View Help
GNU nano 9.1 passwords.txt
admin
password
123456
qwerty
Password1
letmein
welcome
root
Password123
football
```

Figure 1: passwords.txt on Kali - 10 candidate passwords, including the correct one.

```
Session Actions Edit View Help
GNU nano 9.1 user!
administrator
admin
ssss
testvictim
guest
```

Figure 2: users.txt on Kali - 5 candidate usernames, including testvictim.

3. Attack Execution

Attack Command

```
hydra -L users.txt -P passwords.txt -t 1 smb2://192.168.29.226
```

Flag breakdown

- L users.txt: try every username from the file
- P passwords.txt: try every password from the file
- t 1: single-threaded (Windows 10 rate-limits parallel SMB attempts; -t 1 avoids timeouts)
- smb2://192.168.29.226: target Windows SMB2 service on the victim IP

Attacker-side Result

Hydra completed 50 combinations in approximately 4 seconds and recovered valid credentials for **testvictim / Password123**. This is a fully successful credential compromise from the attacker's perspective.

```
(kali@kali)-[~]
$ hydra -L users.txt -P passwords.txt -t 1 -f smb2://192.168.29.226
hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-04 13:27:43
WARNING] Workgroup was not specified, using "WORKGROUP"
[DATA] max 1 task per 1 server, overall 1 task, 50 login tries (l:5/p:10), ~50 tries per task
[DATA] attacking smb2://192.168.29.226:445/
WARNING] 192.168.29.226 might accept any credential
445[smb2] host: 192.168.29.226 login: testvictim password: Password123
[STATUS] attack finished for 192.168.29.226 (valid pair found)
. of 1 target successfully completed, 1 valid password found
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-04 13:27:47

(kali@kali)-[~]
$
```

Figure 3: Hydra output from Kali. Cracked credentials shown in green: login=testvictim, password=Password123, 1 valid password found.

4. Detection in Splunk

The forwarder pipeline had an interesting artifact: shortly after Hydra ran, the SplunkForwarder service on the Windows VM appeared to stall (last event received around 21:27 IST). A service restart on Windows caused the forwarder to catch up and ship the backlog of Security events. This behavior is worth noting: aggressive brute force testing can temporarily saturate small forwarder buffers on a home lab.

```
net stop SplunkForwarder
net start SplunkForwarder
```

Initial Discovery Search

Rather than searching directly for a hard-coded Event ID, the investigation began by looking for any Security log activity referencing the target account name:

```
host=DESKTOP-9M1T24R "testvictim"
```

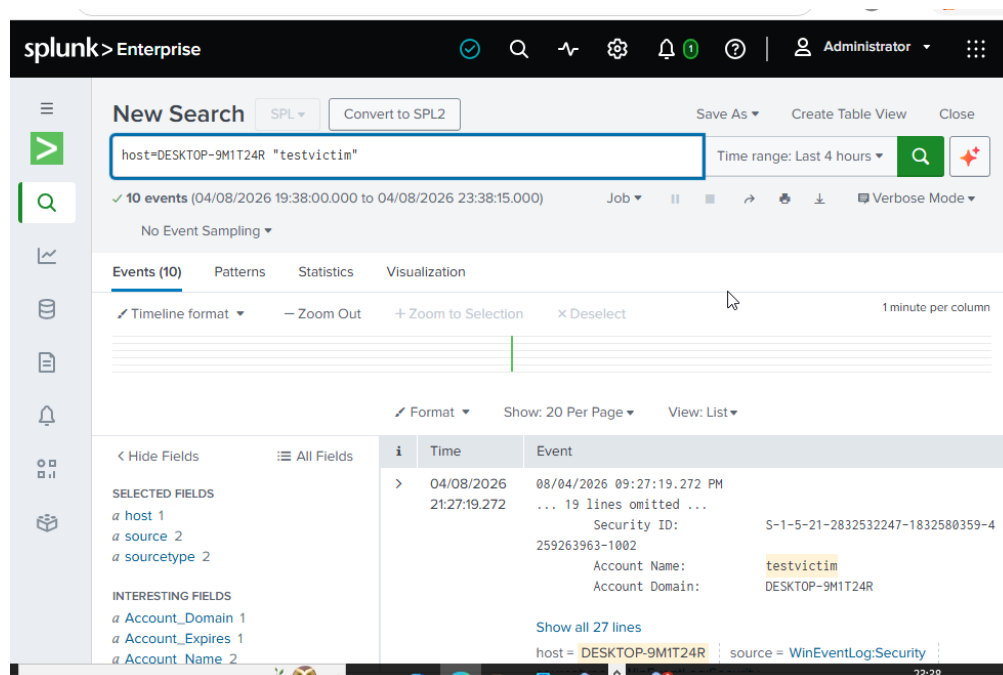


Figure 4: Initial hunt - 10 events referencing 'testvictim' surfaced in a broad search, centered around 21:27:19 IST.

Confirmed Event Count (48 Failed Logons)

Once the attack signature was located, a filtered count query produced the flood signature - **48 failed logon events** concentrated in a ~5-second window:

```
host=DESKTOP-9M1T24R sourcetype="WinEventLog:Security" EventCode=4625
| stats count
```

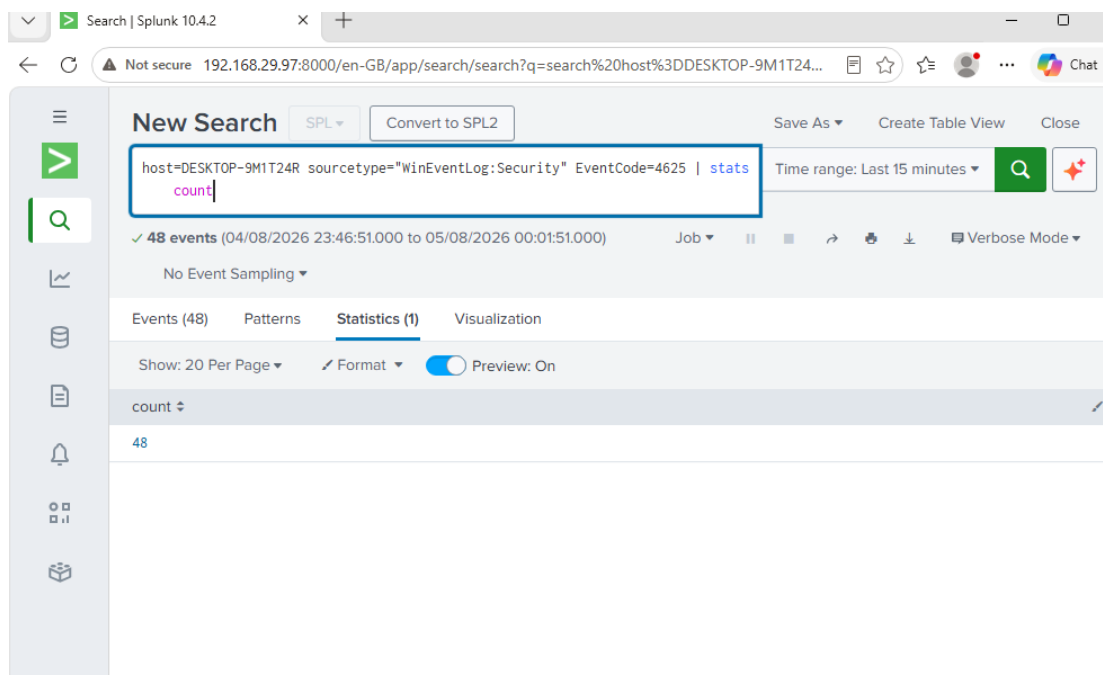


Figure 5: 48 failed login (EventCode=4625) events recorded during the brute-force window - the classic 'flood' signature.

Attribution to a Single Source IP

Every single one of the 48 failed logons traced back to the same source network address - **192.168.29.163 (Kali)**. This single-source concentration is one of the strongest indicators of automated credential guessing versus organic user error:

```
host=DESKTOP-9M1T24R sourcetype="WinEventLog:Security" EventCode=4625
| stats count by Source_Network_Address
```

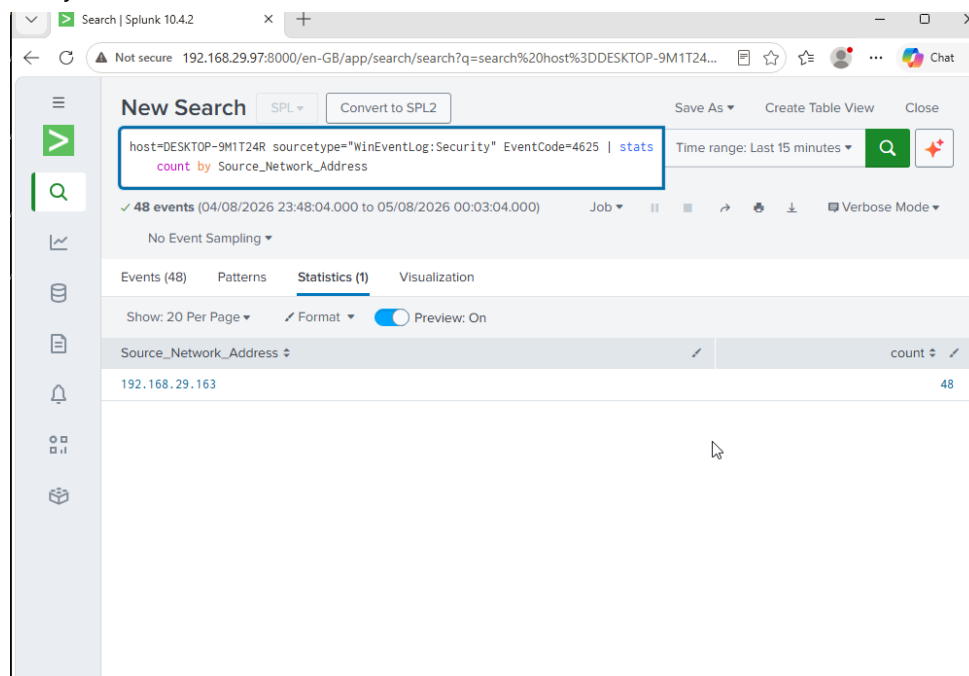


Figure 6: All 48 failures attributed to Source_Network_Address 192.168.29.163 (the Kali attacker).

Failure Reason Confirmation

All 48 events shared the same Windows failure reason: **"Unknown user name or bad password"** - textbook credential guessing:

```
host=DESKTOP-9M1T24R sourcetype="WinEventLog:Security" EventCode=4625
| stats count by Failure_Reason
```

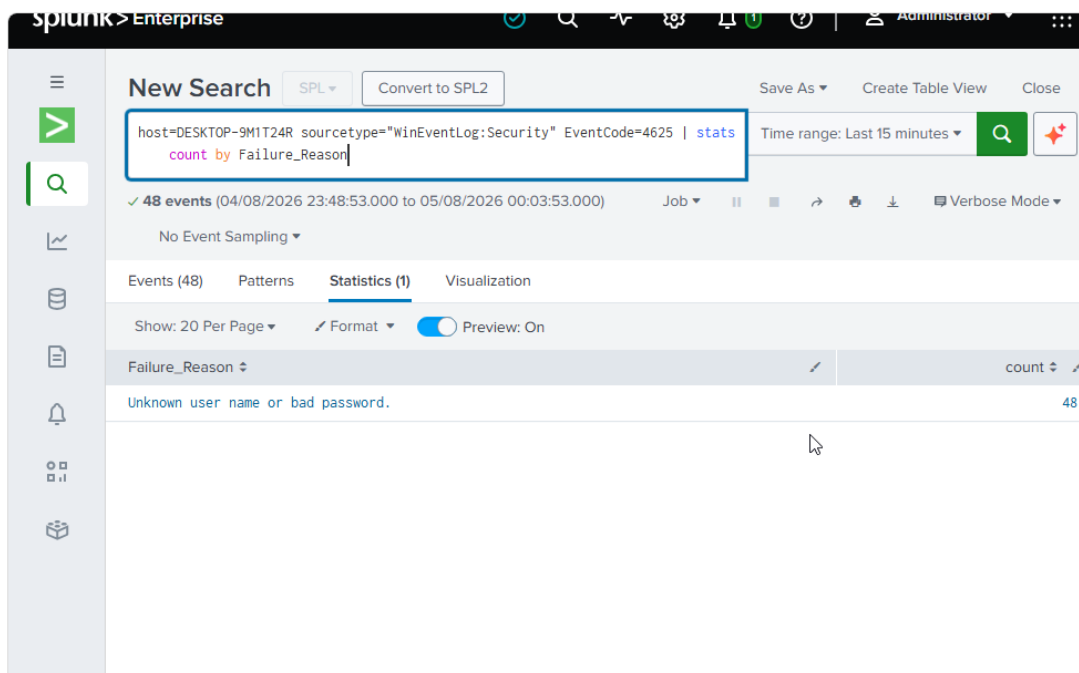


Figure 7: All 48 events share a single Failure_Reason - a classic dictionary-attack signature.

Individual Evidence Event (4625) - Full Detail

One 4625 event was expanded to inspect the raw fields. Every field needed for a formal incident write-up is captured here:

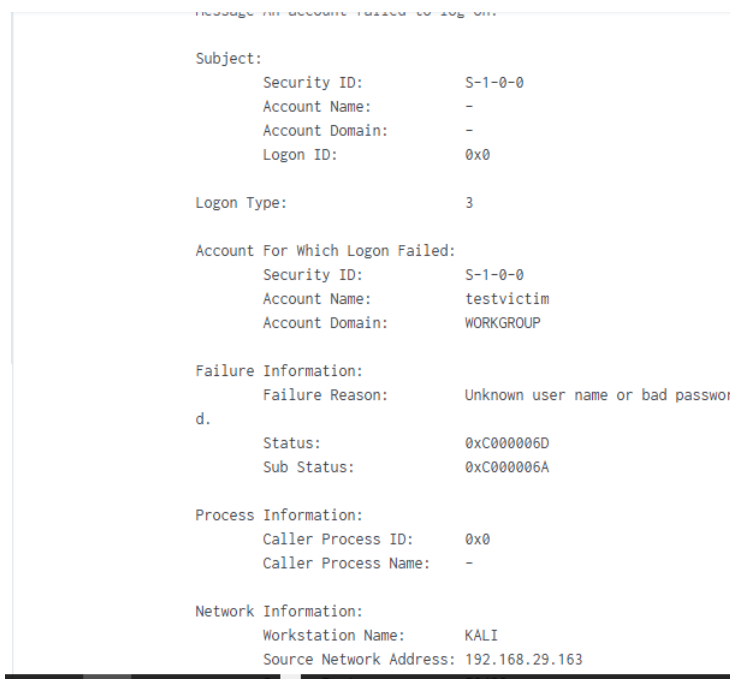


Figure 8: Expanded failed logon event. Logon Type 3 (network/SMB), target account testvictim, failure reason 'Unknown user name or bad password', Sub Status 0xC000006A (wrong password), Workstation Name KALI, Source Network Address 192.168.29.163.

Field	Value	Analyst Interpretation
EventCode	4625	Failed logon event
Logon Type	3	Network logon - matches SMB session semantics
Account For Which Logon Failed	testvictim	The targeted local account on Windows

Account Domain	WORKGROUP	Local (non-domain) authentication
Failure Reason	Unknown user name or bad password	Windows will not disambiguate - typical credential guessing signal
Status	0xC000006D	STATUS_LOGON_FAILURE
Sub Status	0xC000006A	STATUS_WRONG_PASSWORD - user exists, password wrong
Workstation Name	KALI	Attacker announced its own hostname in the SMB session
Source Network Address	192.168.29.163	Attacker IP - matches Kali VM
Authentication Package	NTLM (NtLmSsp)	Legacy Windows challenge/response auth over SMB

5. Investigation Analysis

The 6-Question Framework Applied

Question	Answer
WHO (Source)	Attacker at 192.168.29.163. Workstation Name announced in SMB session as "KALI", indicating a Kali Linux origin. Behaviour is consistent with an automated SMB brute-force tool such as Hydra, CrackMapExec, or similar. Ground truth in this exercise confirms the tool was Hydra v9.7.
WHAT (Activity)	SMB2 credential brute force. 48 failed logon events (Event ID 4625) plus 1 successful logon (Event ID 4624) captured within a 5-second window.
WHEN (Timestamp)	August 4, 2026 at 23:54:21 IST. Attack duration approximately 4 seconds end-to-end.
WHERE (Target)	Windows 10 endpoint DESKTOP-9M1T24R (192.168.29.226), SMB port 445. Local account testvictim in WORKGROUP domain.
HOW (Method)	Hydra dictionary attack driving SMB2. 5-username x 10-password wordlist (50 combinations). Logon Type 3 (network). Authentication package NTLM (NtLmSsp).
WHY IT MATTERS	The attack succeeded - Hydra cracked testvictim / Password123. This is a full credential compromise affecting all three CIA pillars: confidentiality (attacker can read files as testvictim), integrity (files can be modified or deleted under this identity), and availability (attacker could install malware, disrupt services, or use this foothold for lateral movement). Credential-based initial access is the #1 real-world intrusion vector, making this a high-priority incident.

MITRE ATT&CK; Mapping

Technique	Tactic	Description
T1110	Credential Access	Brute Force (parent technique)
T1110.001	Credential Access	Password Guessing - trying multiple passwords against one or more accounts
T1021.002	Lateral Movement	SMB / Windows Admin Shares - target protocol used for authentication
T1078.003	Persistence / Initial Access	Valid Accounts (Local) - the compromised account is a local Windows user

Key Observations

- **Attack was extremely fast and loud.** 48 failed logons in ~5 seconds is a very high rate and would trivially trigger any well-tuned Splunk alerting rule (e.g. "more than 10 EventCode=4625 from a single Source_Network_Address in 60 seconds").
- **All 48 failures share the same Failure Reason and Sub Status (0xC000006A).** Sub Status 0xC000006A means "user exists, wrong password" - not "unknown user". This tells the analyst that Hydra was hammering an account that Windows recognizes, which is a stronger indicator of a real threat than random password spraying.
- **Discrepancy between Hydra's 50 attempts and Windows' 48 recorded failures.** Two attempts did not produce 4625 events. Possible explanations: (1) the successful attempt (testvictim/Password123) generated a 4624 instead of a 4625, and (2) one attempt may have been consumed by SMB negotiation before reaching the authentication subsystem. This kind of counting discrepancy is worth noting in any real incident because it is where evasion techniques hide.
- **Forwarder stall behavior.** Immediately after the brute force flood, the SplunkForwarder on Windows stopped shipping events until a manual restart. In a production SIEM, this would be a critical blind-spot: an attacker who follows brute force with post-exploitation activity could operate unmonitored until the forwarder recovers. Buffer sizing and forwarder health monitoring are worth alerting on.
- **Attacker OpSec was poor.** Kali announced its own hostname ("KALI") in the Workstation Name field of every failed logon. In a real attack, an adversary would spoof this. Its presence in the logs is a free attribution win.

6. Recommended Remediations

Immediate (Containment)

1. Quarantine the affected endpoint DESKTOP-9M1T24R from the network to prevent lateral movement.
2. Disable the compromised testvictim local account.
3. Force password reset on any other local account that may share the same weak password pattern.
4. Block the attacker source IP 192.168.29.163 at the perimeter firewall.

Investigation (Follow-up)

5. Trace all file access, process creations (Sysmon EID 1), and network activity (Sysmon EID 3) tied to the testvictim account after the 23:54:21 timestamp to identify any post-compromise activity.
6. Review all 4624 (successful logon) events from 192.168.29.163 across the whole environment to confirm scope.
7. Check for new local account creation (Event ID 4720) and privilege changes (4728, 4732) after the compromise time.

Long-Term (Prevention)

8. Build a Splunk correlation alert: more than 10 failed logon (EventCode=4625) events from a single Source_Network_Address within 60 seconds should trigger a real-time notable event.
9. Enforce Windows account lockout policy (e.g. 5 failed attempts = 30-minute lockout) to prevent Hydra-style attacks from completing.
10. Disable NTLM authentication where possible in favor of Kerberos; NTLM is well past its useful life.
11. Restrict SMB access to trusted network segments only. Home SMB exposure to a shared network is a common real-world foothold.
12. Enforce a strong password policy that would defeat a 10-word dictionary trivially (12+ chars, complexity).

7. Skills Demonstrated

- Executed a real credential brute-force attack (Hydra) against a lab endpoint over SMB2.

- Investigated the resulting security events in Splunk without knowing the target Event ID in advance, using a progressive-narrowing hunt methodology.
- Wrote SPL queries with stats and grouping to build attribution tables from raw Windows Security events.
- Correctly identified and interpreted Windows Event IDs 4624/4625, Logon Type 3, Failure Reasons, and NTLM sub-status codes (0xC000006A).
- Diagnosed and fixed a Splunk Universal Forwarder stall triggered by the volume of failed-logon events.
- Mapped the observed activity to MITRE ATT&CK; techniques T1110.001, T1021.002, and T1078.003.
- Produced a structured incident report following the 6-Question analyst framework.

Report prepared by Sree Saran S S as part of SOC Analyst (L1) training and portfolio development.